



12th Project

Risk Management

Nada Ibrahim	221003011
Mawada Ayman	221003907
Haidy Hassanin	221003900
Habiba Hesham	221003746

Lecturer: Dr.Nada Hany

TA: Eng.Nour Ehab

Part 2 - Project Requirements & Tasks

Task 1: Risk Identification and Statements

- 1. Identify Risks: Extract exactly five (5) distinct cybersecurity risks from the narration. Ensure these 5 risks cover at least 3 different domains (e.g., physical, network, application, operations).**

Risk ID	Risk	Domain
R1	Labs VLAN routes directly to Servers VLAN without firewall.	Network
R2	API key is hardcoded in frontend JavaScript.	Application
R3	Backup NAS is located on the same network segment as production.	Operations
R4	Biometric IoT devices use default administrator credentials on the same VLAN as Student WiFi.	Network (IOT)
R5	Server closet doors inside computer labs are frequently left open and physically unsecured.	Physical

2. Risk Statements: Write a formal risk statement for each of the 5 identified risks using the strict Cause–Event–Impact format.

Risk ID	Risk Statement
R1	Due to the misconfiguration allowing the Labs VLAN to communicate directly with the Servers VLAN without firewall inspection, attackers may gain unauthorized access to critical university servers, leading to sensitive data exposure and service disruption.
R2	Due to the payment gateway API key being hardcoded in the frontend JavaScript and publicly visible, attackers may steal and misuse the API credentials, resulting in unauthorized financial transactions and potential data compromise.
R3	Due to the backup NAS sharing the same network segment and Active Directory domain as the production environment, ransomware attacks may spread to the backup systems, leading to backup deletion and permanent data loss.
R4	Due to many biometric IoT devices still using default administrator credentials and being connected to the same VLAN as the student WiFi network, attackers may compromise these devices and gain unauthorized network access, resulting in manipulation of attendance records and exposure of biometric data.
R5	Due to server closet doors inside computer labs frequently being left open, unauthorized individuals may gain physical access to network infrastructure and servers, leading to device tampering or service interruption.

Task 2: Vulnerability Assessment (CVSS v4.0)

Selected Vulnerability: Hardcoded Payment Gateway API Key in Frontend JavaScript (R2)

Metric	Selected Value	Justification
Attack Vector (AV)	Network (N)	The API key is embedded in the website frontend and is publicly visible over the internet.
Attack Complexity (AC)	Low (L)	The key is hardcoded and publicly visible(requiring no technical complexity or conditions to view)
Attack Requirements (AT)	None (N)	There are no specific deployment or architecture conditions required for the attack to succeed.
Privileges Required (PR)	None (N)	The attacker does not need any account or authentication to access the frontend code and see the key.
User Interaction (UI)	None (N)	The attacker can extract the key independently without requiring any action from a legitimate user.
Vulnerable System Confidentiality (VC)	High (H)	The case study explicitly states that the API key is visible to anyone who inspects the webpage source code, representing a total loss of confidentiality of a sensitive payment credential.
Vulnerable System Integrity (VI)	None (N)	The case study does not indicate that GHU's website itself is modified or corrupted as a result of the key exposure.
Vulnerable System Availability (VA)	None (N)	The case study does not indicate that GHU's payment portal experiences any downtime or disruption due to the key exposure.
Subsequent System Confidentiality (SC)	High (H)	The stolen API key grants unauthorized access to the third-party payment gateway, exposing sensitive financial data and transaction records.
Subsequent System Integrity (SI)	High (H)	An attacker can use the stolen key to perform unauthorized payment operations directly on the third-party payment gateway.
Subsequent System Availability (SA)	None (N)	The case study does not explicitly state that the third-party payment gateway service will be disrupted or denied.



Common Vulnerability Scoring System Version 4.0 Calculator

CVSS:4.0/AV:N/AC:L/AT:N/PR:N/UI:N/VC:H/VI:N/VA:N/SC:H/SI:H/SA:N

Reset

CVSS v4.0 Score: **9.3 / Critical** ⊕

Exploitability Metrics

Attack Vector (AV):

Network (N)

Adjacent (A)

Local (L)

Physical (P)

Attack Complexity (AC):

Low (L)

High (H)

Attack Requirements (AT):

None (N)

Present (P)

Privileges Required (PR):

None (N)

Low (L)

High (H)

User Interaction (UI):

None (N)

Passive (P)

Active (A)

Vulnerable System Impact Metrics

Confidentiality (VC):

High (H)

Low (L)

None (N)

Integrity (VI):

High (H)

Low (L)

None (N)

Availability (VA):

High (H)

Low (L)

None (N)

Subsequent System Impact Metrics

Confidentiality (SC):

High (H)

Low (L)

None (N)

Integrity (SI):

High (H)

Low (L)

None (N)

Availability (SA):

High (H)

Low (L)

None (N)

Vector String:

CVSS:4.0/AV:N/AC:L/AT:N/PR:N/UI:N/VC:H/VI:N/VA:N/SC:H/SI:H/SA:N

Base Score: 9.3 / Critical

The vulnerability selected for this assessment is the hardcoded payment gateway API key embedded in the frontend JavaScript of GHU's payment portal (R2). For the Exploitability metrics, the **Attack Vector** was set to **Network** because the case study states that the API key is visible to anyone who inspects the webpage source code, meaning it can be accessed from anywhere over the internet.

Attack Complexity was set to **Low** since no special skills or tools are needed to find the key. **Attack Requirements** and **Privileges Required** were both set to **None** because the key is always exposed and no account or login is needed to view it. **User Interaction** was also set to **None** as the attacker can retrieve the key completely on their own.

For the Impact metrics, Vulnerable System Confidentiality was rated High because the API key itself is a sensitive credential that is fully exposed. Vulnerable System Integrity and Availability were both rated None since the case study does not mention any modification or disruption to GHU's website.

Subsequent System Confidentiality and Integrity were both rated High because an attacker can use the stolen key to access financial data and perform unauthorized transactions on the third-party payment gateway. Subsequent System Availability was rated None as the case study does not indicate any disruption to the payment gateway service.

Task 3: Quantitative Risk Assessment

1. FAIR Application Select one (1) financial or data-loss risk from Task 1.
1. Apply the FAIR (Factor Analysis of Information Risk) ontology.
Break down the Loss Event Frequency (LEF) and Loss Magnitude (LM) into their sub-components.

The Chosen Risk: Hardcoding an API key in frontend JavaScript can allow attackers to extract it and misuse it which leading to unauthorized access, financial loss or data exposure

Scenario Statement: Risk of unauthorized financial transactions and payment data exposure caused by attackers exploiting a hardcoded API key exposed in GHU's frontend JavaScript within the next 12 months. The loss event is defined as a successful unauthorized financial transaction using the exposed API key.

$$\text{Loss Event Frequency (LEF)} = (\text{TEF}) \times \text{Susceptibility}$$

1) Threat Event Frequency (TEF) $\text{TEF} = \text{CF} \times \text{PoA}$

- CF (Contact Frequency): assuming CF = 5,000 contacts/year.

Although GHU has 20,000 students accessing the payment portal CF represents only those who inspect the page source or use automated scanners estimated as a fraction of the total user base.

- PoA (Probability of Action):

Out of the 5,000 contacts who accessed and viewed the API key what percentage would act on it?

Based on the project Overview:

1. The API key is directly visible in frontend JavaScript So no technical skill required
2. The payment gateway handles real tuition fees So high financial incentive
3. There is no SOC or monitoring to detect misuse
4. There is no rate limiting on the API

Assumption:

Assuming PoA = 0.02 (2%) While the API key is freely visible to anyone inspecting the page source not all contacts have malicious intent.

Threat Event Frequency (TEF) = CF × PoA = 5,000 × 0.02 = 100 threat events/year

2) Susceptibility (Susc):

Out of the 100 threat events how many actually result in a loss event (successful misuse of the API key)?

Susceptibility = f (Threat Capability vs Resistance Strength)

- **Threat Capability (TCap):**

Based on the case study:

- No technical skill required the API key is plainly visible
- Any developer or student can misuse it directly
- Low-to-moderate capability attackers can succeed easily

Estimating TCap at the 50th–70th percentile. The attack requires minimal skill, as the API key is directly readable from the page source without any reverse engineering or exploitation

- **Resistance Strength (RS):**

Based on the case study:

- WAF is disabled during Registration Week
- No backend API protection
- No monitoring or SOC
- No rate limiting on the API

Estimating RS at the 20th–30th percentile. GHU has virtually no controls protecting the API key from misuse the WAF is disabled during peak periods and there is no monitoring in place Since TCap > RS, Susceptibility is high.

- Assuming Susc = 0.30 (30%). Since \$TCap > RS\$ (Threat Capability is higher than GHU's Resistance Strength due to the absolute exposure of the clear-text API key and the lack of a SOC

or monitoring), the susceptibility is High (30%). This means 30% of actual malicious attempts will successfully result in a loss event.

Loss Event Frequency (LEF) = TEF × Susc = 100 × 0.30 = 30 loss events/year

Loss Magnitude (LM) = Primary Loss (PL) + Secondary Loss (SL)

- **Primary Loss (PL):** Primary Loss is the direct loss that occurs immediately from the loss event.

Based on the case study, when an unauthorized transaction occurs:

1) Financial Loss:

Assume a direct financial loss between \$5,000 and \$15,000 per incident due to unauthorized transactions made through the payment gateway using the exposed API key.

2) Response Cost:

Assume response costs between \$3,000 and \$8,000 per incident. These costs include the IT team's effort to investigate the incident, stop the attack, and recover affected systems.

3) Replacement Cost:

Assume replacement costs between \$1,000 and \$3,000 per incident. This includes changing the API key, fixing the frontend code, and updating the payment system integration.

Total Primary Loss (PL) PL=9000–26000 per loss

- **Secondary Loss (SL)**

Secondary Loss represents harm to external parties as a result of the primary loss event.

SL = SLEF × SLM

SLEF Assumption:

Assuming SLEF = 0.80, meaning that 80% of loss events will result in secondary losses. Given the absence of a SOC and monitoring, most incidents will go undetected long enough to cause reputational and regulatory impact.

1) Regulatory Fines

Assume regulatory fines between \$20,000 and \$100,000 per incident. Since the exposed API key is related to payment processing, the university may face PCI-DSS compliance penalties depending on how serious the incident is and how long the issue remains unresolved.

- **Min: \$20,000, Max: \$100,000**
- **Most Likely: \$60,000 (A moderate PCI-DSS compliance penalty based on the prolonged exposure duration)**

2) Reputation Damage

Assume reputation-related losses between \$15,000 and \$50,000 per incident. Because GHU has more than 20,000 students, a public security breach could affect student trust and harm the university's reputation, which may also impact future enrollment.

- **Min: \$15,000 | Max: \$50,000**
- **Most Likely: \$31,500 (Estimated cost for student retention campaigns and PR dynamic response).**

3) Legal Liability

Assume legal costs between \$10,000 and \$40,000 per incident. These costs may include legal fees, investigations, or compensation claims from students whose financial information was exposed or misused.

Most Likely: \$20,000 (Average cost for legal defense and minor settlement claims).

Total Secondary Loss Magnitude (SLM) Parameters:

Minimum SLM: \$20,000 + \$15,000 + \$10,000 = \$45,000

Maximum SLM: \$100,000 + \$50,000 + \$40,000 = \$190,000

Most Likely SLM: \$60,000 + \$31,500 + \$20,000 = \$111,500 (This justifies the baseline scenario)

Expected Most Likely Secondary Loss (SL):

$SL = SLEF * \text{Most Likely SLM} = 0.80 * 111,500 = \$89,200$

Total Most Likely Loss Magnitude (LM) for the Scenario:

LM = Primary Loss Most Likely + Expected Secondary Loss

$LM = \$17,500 + \$89,200 = \$106,700$

Annual Loss Exposure (ALE)

The Annual Loss Exposure represents the total expected financial impact of this risk over a 12-month period, combining both the frequency and magnitude of loss events.

$ALE = LEF \times \text{Most Likely LM} = 30 \times \$106,700 = \$3,201,000/\text{year}$

This figure indicates that GHU is exposed to an estimated annual financial risk of over \$3.2 million due to the hardcoded API key vulnerability.

Given the absence of a SOC, monitoring controls, and rate limiting on the payment gateway API, this level of exposure justifies immediate remediation as a high-priority risk treatment action.

Component	Value
CF	5,000
PoA	2%
TEF	100
Susc	30%
LEF	30
PL (range)	\$9,000–\$26,000
SLM (range)	\$45,000–\$190,000
SLEF	80%
SL (range)	\$36,000–\$152,000
LM (range)	\$45,000–\$178,000
Most Likely LM	\$106,700

Task 4: Qualitative Risk Assessment

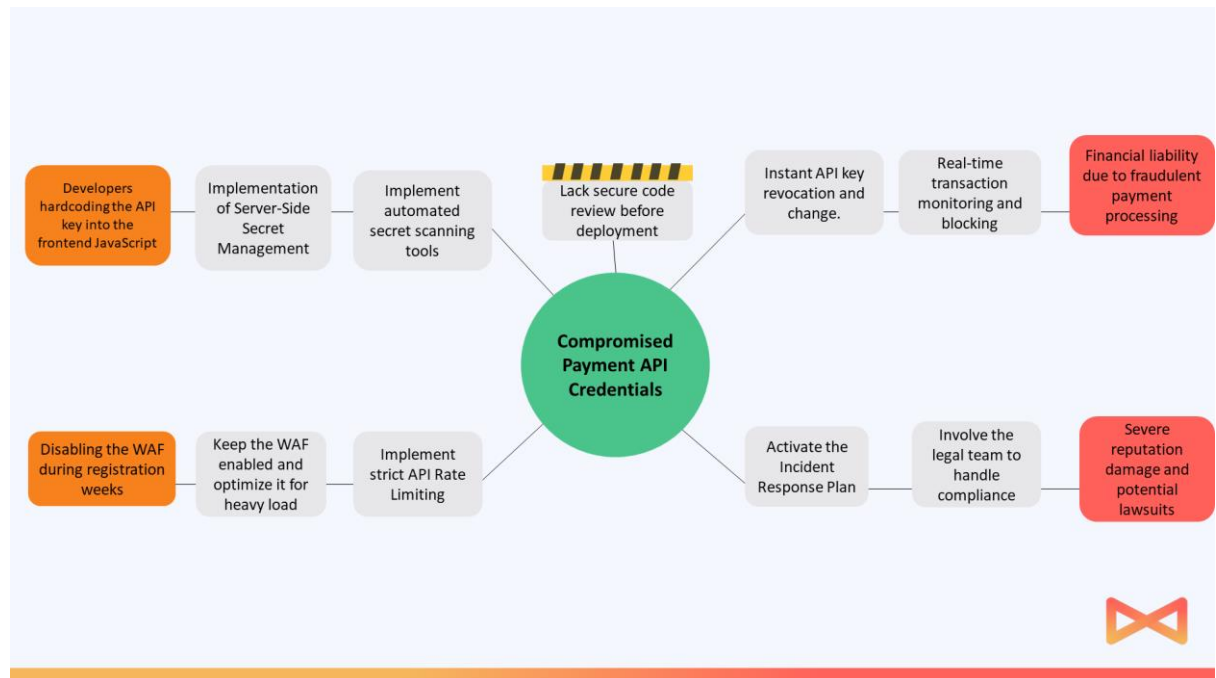
1. Risk Register: Create a comprehensive Risk Register in a table format that includes all five (5) risks identified in Task 1.

Risk ID	Affected Asset	Existing Controls	Likelihood (1-5)	Impact (1-5)	Risk Score	Risk Level	Mitigation
R1	Core University Servers and Database Systems	Basic network segmentation (misconfigured).	5	5	25	Critical	Reconfigure VLAN segmentation and enforce firewall inspection
R2	Payment Gateway System and Financial Data	HTTPS encryption only (no backend API protection).	5	5	25	Critical	Move API key to secure backend storage and implement key rotation
R3	Backup Systems and NAS Storage	Daily backups exist (not isolated).	4	5	20	High	Isolate backup network and maintain offline backups
R4	Biometric Scanners and Attendance System	Basic network controls, no IoT hardening.	5	5	25	Critical	Change default credentials and isolate IoT devices in separate VLAN
R5	Network Switches and Server Rooms	Basic lab supervision only.	3	4	12	High	Enforce physical access control and secure server rooms

**2. Risk Matrix: Define your own 5x5 Likelihood and Impact scales (1-5).
Assess the inherent risk for each of the 5 items and plot them on a
5x5 Heat Map / Risk Matrix.**

Likelihood ↑	5 Almost certain	5	10	15	20	25 (R1) (R2) (R4)
	4 Likely	4	8	12	16	20 (R3)
	3 Possible	3	6	9	12 (R5)	15
	2 Unlikely	2	4	6	8	10
	1 Rare	1	2	3	4	5
		1 Negligible	2 Minor	3 Moderate	4 Major	5 Severe
		Impact →				

- Bow-Tie Analysis: Select the highest-rated risk from your Risk Matrix. Perform a Bow-Tie analysis detailing exactly: 1 risk event, 2 root causes, 2 consequences, 2 preventative controls, and 2 reactive controls.**



Task 5: Risk Treatment & Framework Mapping

- NIST RMF / Controls: Take the top three (3) highest risks from your Risk Register (Task 4). Propose a specific risk treatment strategy for each (Mitigate, Transfer, Avoid or Accept).**
- Control Mapping: For each of the 3 risks, map your proposed mitigations to exactly two (2) specific controls within NIST SP 800-53 (provide the control ID and name, e.g., AC-2 Account Management).**

Risk ID	Risk Treatment Strategy	Proposed Mitigation Action	Mapped NIST SP 800-53 Controls
R1	Mitigate	1. Fix the core switch routing to block the direct link from Labs to Servers. 2. Put an internal firewall between them to inspect all traffic.	• AC-4 Information Flow Enforcement • SC-7 Boundary Protection
R2	Mitigate	1. Delete the API keys from the frontend JavaScript code. 2. Save them safely in server environment variables and start doing code reviews.	• SC-28 Protection of Information at Rest • SA-11 Developer Testing and Evaluation
R4	Mitigate	1. Change all factory default passwords on the biometric scanners immediately. 2. Move these IoT devices to a separate VLAN away from the student WiFi.	• IA-2 Identification and Authentication • SC-39 Process Isolation